

NT230

CƠ CHẾ HOẠT ĐỘNG CỦA MÃ ĐỘC

GV: TS. Phan Thế Duy

Trường Đại học Công nghệ Thông tin
Đại học Quốc gia Thành phố Hồ Chí Minh

Phân tích cơ chế · Kiểm chứng bằng chứng · Giải thích giới hạn





Buổi 01

Tổng quan môn học và phương pháp nhìn nhận mã độc

Câu hỏi xuyên suốt

Một dấu hiệu đáng nghi đã đủ để kết luận có mã độc chưa?

- 100 phút trên lớp; các trang “Tự học / tra cứu” dùng để đọc lại.
- Đầu ra: một kết luận có bằng chứng và giới hạn.

Nội dung chính

- 1 Làm quen với học phần
- 2 Mã độc và các cách phân loại
- 3 Vòng đời và chuỗi hành vi
- 4 Phân tích dựa trên bằng chứng
- 5 Luyện tập và đánh giá cá nhân
- 6 An toàn thực hành và bối cảnh AI
- 7 Kết thúc buổi học

1

Làm quen với học phần

Câu hỏi trọng tâm

Học gì, được đánh giá thế nào và đề án bắt đầu khi nào?

Sau học phần, sinh viên có thể

- Giải thích vòng đời, cấu trúc tệp và cơ chế thực thi mã độc.
- Tái dựng chuỗi hành vi bằng dấu vết tệp, tiến trình, bộ nhớ và mạng.
- Kiểm chứng phát hiện bằng dữ liệu đối chứng; phản biện nhận định về AI.
- Báo cáo có khả năng tái lập và bảo vệ kết luận cá nhân.

Vì sao cần hiểu cơ chế: giải thích đúng

Từ cảnh báo đến câu hỏi

Tên công cụ hoặc nhãn antivirus chỉ là điểm bắt đầu. Cần xác định mã làm gì, với quyền nào và trong điều kiện nào.

Giá trị thực tiễn

Hiểu cơ chế giúp phân biệt cập nhật hợp lệ với hành vi lạm dụng có hình thức tương tự; giảm kết luận quá mức.

Nguồn: MITRE: Detection and Analytics; Get Started

Vì sao cần hiểu cơ chế: can thiệp đúng

Tự học / tra cứu



Ví dụ lập luận

Nếu mã lan qua dịch vụ mạng, chỉ xóa tệp chưa xử lý đường lan. Cần khắc phục điều kiện khai thác và kiểm chứng phạm vi ảnh hưởng.

Nguồn: MITRE S0366: WannaCry

Khối lượng và kiến thức đầu vào

Học phần	Chuẩn bị
3 tín chỉ: 2 LT + 1 TH	Học trước: Lập trình hệ thống NT209
15 buổi LT; 6 buổi TH	Đọc C/C++ hoặc Python; tiến trình, bộ nhớ
30 tiết LT + 30 tiết TH	TCP/IP, DNS; đọc luồng lệnh cơ bản
98 giờ tự học; thi 120 phút	Thi cuối kỳ theo lịch riêng

Nội dung từng buổi: 1–4

Tự học / tra cứu

Buổi	Nội dung và việc SV thực hiện
1	Tổng quan, phân loại, vòng đời; lập luận có bằng chứng.
2	PE, ánh xạ tệp–bộ nhớ, loader; đối chiếu ELF.
3	Lây tệp; injection và hollowing; phân biệt tệp với tiến trình.
4	Worm, mô hình lan; nộp đề xuất đồ án.

Nội dung từng buổi: 5–8

Tự học / tra cứu

Buổi	Nội dung và việc SV thực hiện
5	Botnet, C2, DNS/DGA; dựng timeline mạng.
6	Delivery, dropper/loader; macro, LNK và ClickFix.
7	Service/task/Registry; infostealer, quyền và dữ liệu phiên.
8	Ransomware, khóa và phục hồi; bằng chứng đồ án sơ bộ.

Nội dung từng buổi: 9–12

Tự học / tra cứu

Buổi	Nội dung và việc SV thực hiện
9	Rối mã, packing/unpacking; giới hạn của entropy.
10	Biến đổi mã; anti-debug, anti-VM; rootkit ở mức cơ chế.
11	Fileless, PowerShell/WMI/LOLBins; bản đồ dấu vết.
12	Bộ nhớ, YARA/Sigma; đối chứng, precision/recall; gói tái lập.

Nội dung từng buổi: 13–15

Tự học / tra cứu

Buổi	Nội dung và việc SV thực hiện
13	AI, kiểm chứng CTI; đối sánh Linux/chuỗi cung ứng.
14	Báo cáo đề án, phản biện và vấn đáp từng thành viên.
15	Hoàn tất vấn đáp; tình huống tích hợp và tổng hợp kiến thức.

Sáu buổi thực hành

- Lab 1: PE và quan sát thực thi.
- Lab 2–3: duy trì; lan truyền và C2 có đối chứng.
- Lab 4–5: injection; unpacking và chống phân tích.
- Lab 6: fileless và kiểm chứng phát hiện.
- Mỗi SV nộp báo cáo riêng và thực hiện biểu thể kiểm tra cá nhân.

Vận dụng nghề nghiệp: phân tích mã độc

Tự học / tra cứu

Nhiệm vụ

Giải thích luồng thực thi, hành vi và điều kiện kích hoạt của mẫu chưa biết.

Minh chứng sau môn học

Báo cáo có chú giải mã, sơ đồ hành vi và kết quả đối chứng từ lab/đồ án.

Bước phát triển tiếp

Rèn assembly và hệ điều hành; xây hồ sơ phân tích tái lập. Tên vị trí tùy tổ chức.

Nguồn: NIST NICE: mô tả công việc qua nhiệm vụ, kiến thức, kỹ năng

Vận dụng nghề nghiệp: SOC và phát hiện

Tự học / tra cứu

Nhiệm vụ

Phân loại cảnh báo, nối cây tiến trình với log mạng; phát triển và kiểm tra luật phát hiện.

Liên hệ học phần

Buổi 5, 11–12: C2, dấu vết fileless, YARA/Sigma và đánh giá dương tính giả/ âm tính giả.

Sản phẩm nghề nghiệp

Một luật kèm dữ liệu lành/độc, kết quả đo và giới hạn áp dụng; không chỉ ảnh chụp cảnh báo.

Nguồn: MITRE: Detections and Analytics

Vận dụng nghề nghiệp: điều tra và ứng phó

Tự học / tra cứu

Nhiệm vụ

Tái dựng diễn biến, xác định phạm vi và đề xuất xử lý dựa trên bằng chứng.

Liên hệ học phần

Buổi 7–8, 11–12: persistence, đánh cắp, ransomware và bộ nhớ.

Sản phẩm nghề nghiệp

Timeline có nguồn, khoảng trống dữ liệu và ưu tiên thu thập; báo cáo phục vụ quyết định cô lập, phục hồi.

Nguồn: NIST NICE, SP 800-181 Rev. 1

Vận dụng nghề nghiệp: CTI và nghiên cứu

Tự học / tra cứu

Nhiệm vụ

Tình báo mối đe dọa (CTI): so sánh TTP, kiểm chứng báo cáo chiến dịch; đánh giá một phương pháp hoặc công cụ phân tích.

Liên hệ học phần

Buổi 10, 12–14: thử giả thuyết, đối chứng, phản biện AI và bảo vệ kết quả.

Hướng mở rộng

Nghiên cứu bảo mật hoặc mô phỏng đối thủ có ủy quyền. Môn học tạo nền tảng; năng lực nghề cần thực hành tiếp.

Nguồn: MITRE: Threat Intelligence; Adversary Emulation

Điểm môn học

Thành phần	Tỷ lệ	Hình thức đánh giá
Quá trình	25%	Bài tập, quiz, chuyên cần và đồ án (sản phẩm nhóm, vấn đáp cá nhân)
Thực hành	25%	Đánh giá qua 6 lab; tổng trọng số 25% điểm môn học
Cuối kỳ	50%	Thi 90 phút, gồm tự luận và trắc nghiệm. Phần tự luận có 1 câu hỏi về đồ án môn học.

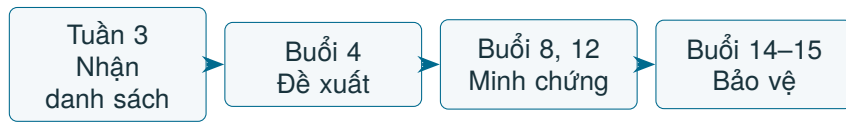
Câu hỏi đồ án trong bài thi

Đánh giá mức độ hiểu và khả năng giải thích của từng sinh viên; không tính lại điểm sản phẩm nhóm.

Đồ án được giao vào tuần thứ 3

- GV công bố danh sách chủ đề được chọn lựa vào tuần 3.
- Nhóm đăng ký lựa chọn theo hướng dẫn của GV trên LMS.
- Chương trình tài năng: tối đa 3 SV/nhóm.
- Chương trình chuẩn: tối đa 4 SV/nhóm.
- Mọi thành viên phải có đóng góp và bảo vệ kết luận cá nhân.

Các mốc đồ án



Điểm cần nhớ

Nộp bản cuối trong 7 ngày sau buổi 15. Tuần là mốc lịch; buổi là mốc nội dung, GV đối chiếu lịch thực tế.

Sản phẩm đồ án cần chứng minh điều gì?

- Một câu hỏi phân tích có phạm vi rõ và mẫu/dữ liệu được GV cho phép.
- Báo cáo 20-25 trang, không tính phụ lục; log hoặc artefact, cấu hình và hướng dẫn tái lập.
- Đối chứng hoặc baseline, kết quả kiểm tra và giới hạn kết luận.
- Nhật ký đóng góp; phụ mục kiểm chứng và khai báo sử dụng AI.

Điểm đồ án và trách nhiệm cá nhân

Sản phẩm nhóm: 75%	Vấn đáp cá nhân: 25%
Đúng cơ chế: 30%	Giải thích cơ chế: 4/10
Bằng chứng và tái lập: 35%	Diễn giải bằng chứng: 3/10
Kiểm chứng và AI: 25%	Giới hạn, tình huống mới: 2/10
Báo cáo, trách nhiệm: 10%	Đóng góp và trung thực: 1/10

Cách học và cách dùng AI

- Đọc trước học liệu; thử giải thích trước khi xem đáp án.
- Dùng AI ở nhiệm vụ cho phép và tự kiểm chứng mọi kết luận.
- Khai báo công cụ, mục đích, đầu ra đã dùng và bước kiểm chứng.
- Không dùng AI trong quiz có giám sát, vấn đáp và thi.
- GV cung cấp đầu ra AI tĩnh để không phụ thuộc dịch vụ trả phí.

2

Mã độc và các cách phân loại

Câu hỏi trọng tâm

Cần phân biệt loại mã độc, kỹ thuật và mục tiêu như thế nào?

Mục tiêu của Buổi 1

- Phân loại đúng ít nhất 4/5 tình huống được cung cấp.
- Phân biệt loại mã độc, kỹ thuật thực thi và tác động.
- Giải thích một chuỗi hành vi bằng quan sát, suy luận và giới hạn.
- Bài cá nhân cuối buổi dùng tình huống mới; không chêm khả năng nhớ tên công cụ.

PowerShell đang chạy: có mã độc không?

Dữ kiện ban đầu

Máy có tiến trình PowerShell và một kết nối ra ngoài. Chưa có nội dung lệnh, tiến trình cha hoặc lịch tác vụ.

Cá nhân · 1 phút

Chọn: A. Chắc chắn có mã độc; B. Chắc chắn lành; C. Chưa đủ dữ kiện. Nêu một bằng chứng cần thêm.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Chưa đủ dữ kiện để kết luận

C: cần ngữ cảnh

PowerShell có thể phục vụ quản trị hoặc bị lạm dụng. Cần đọc tiến trình cha, nội dung lệnh, đích kết nối và quyền thực thi.

Ngộ nhận cần tránh

Tên công cụ hợp lệ không bảo đảm hành vi lành; công cụ xuất hiện cũng không tự chứng minh mã độc.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Mã độc là gì?

Định nghĩa

Mã độc (malware) là phần mềm hoặc mã được thiết kế để thực hiện hành vi không được phép, gây hại cho dữ liệu, hệ thống hoặc người sử dụng.

Cho phép cài đặt khác với đồng ý mọi hành vi

Đồng ý cài ứng dụng không đồng nghĩa đồng ý với chức năng bị che giấu. Cần xét phạm vi cho phép của người dùng hoặc chủ thể có thẩm quyền.

Nguyên tắc nhận diện

Xem chức năng, mục đích và ngữ cảnh. Thiếu xác nhận riêng cho một thao tác chưa đủ để kết luận là mã độc.

Nguồn: NIST CSRC: Malware; Sikorski & Honig (2012), Practical Malware Analysis

Mã độc trong hoạt động của tác nhân đe dọa

Tác nhân và công cụ

Tác nhân đe dọa là cá nhân hoặc nhóm thực hiện hoạt động gây hại. Mã độc là một công cụ giúp họ đạt mục tiêu, không phải bản thân tác nhân.

Vai trò trong chuỗi tấn công

Mã độc có thể hỗ trợ thực thi, duy trì truy cập, điều khiển từ xa, đánh cắp dữ liệu hoặc phá hoại. Một chuỗi có thể phối hợp nhiều thành phần.

Không đồng nhất tấn công mạng với mã độc

Tác nhân còn có thể lạm dụng tài khoản và công cụ hợp lệ. Không tìm thấy mã độc chưa đủ để loại trừ khả năng bị xâm nhập.

Nguồn: MITRE ATT&CK: Get Started; Sikorski & Honig (2012), Practical Malware Analysis

Động cơ không đồng nhất với kỹ thuật

Động cơ	Mục tiêu có thể quan sát
Tài chính	Tổng tiền, lấy thông tin truy cập, chiếm tài nguyên.
Gián điệp	Thu thập tài liệu, thư hoặc dữ liệu nhạy cảm.
Phá hoại / gây sức ép	Làm gián đoạn, phá hủy hoặc thao túng dữ liệu.

Giới hạn suy luận

Chức năng mã cho thấy khả năng; động cơ và quy kết tác nhân cần thêm bối cảnh chiến dịch.

Nguồn: NIST SP 800-83 Rev. 1; MITRE S0366

Ba câu hỏi giúp phân loại

Câu hỏi	Góc nhìn	Ví dụ
Nó lan bằng cách nào?	Cơ chế nhân bản	Virus, worm
Nó thực hiện bằng cách nào?	Kỹ thuật thực thi/che giấu	Macro, injection, fileless
Nó gây ra điều gì?	Chức năng hoặc tác động	Đánh cắp dữ liệu, tổng tiền

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Virus: nhân bản gắn với vật chủ

Định nghĩa

Virus là mã có khả năng nhân bản bằng cách gắn/chèn vào vật chủ, như tệp hoặc tài liệu; sự thực thi của vật chủ kích hoạt mã virus.



Điểm cần nhớ

Ví dụ tệp bị chèn mã có khả năng lây. Việc một chương trình tạo tệp khác chưa đủ chứng minh đó là virus.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Worm: tự nhân bản và lan truyền

Định nghĩa

Worm là chương trình có khả năng tự nhân bản và lan sang hệ thống khác mà không cần gắn vào tệp vật chủ; điều kiện lan phụ thuộc từng họ mã.



Điểm cần nhớ

Không cần gắn vào tệp vật chủ như virus. Không phải mọi worm đều dùng cùng một lỗ hổng hoặc đường lan.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Trojan: bề ngoài và chức năng khác nhau

Bề ngoài

Một ứng dụng được giới thiệu là hữu ích hoặc hợp lệ.

Chức năng ẩn

Có chức năng độc hại, chẳng hạn mở truy cập trái phép. Nhãn Trojan mô tả sự nguy trang, không tự khẳng định cách nhân bản.

Phản ví dụ

Ứng dụng có lỗi không tự động trở thành Trojan; cần bằng chứng về chức năng độc hại.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Tác động và vai trò trong chuỗi

Nhãn	Điều cần quan sát
Ransomware	Hạn chế truy cập, thường bằng mã hóa, gắn yêu cầu tiền chuộc
Infostealer / spyware	Thu thập trái phép dữ liệu hoặc hoạt động của người dùng
Bot trong botnet	Nhận điều khiển và thực hiện nhiệm vụ trong mạng bot
Loader / dropper	Nạp hoặc đặt thành phần tiếp theo của chuỗi

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Ransomware và wiper: phân biệt mục tiêu

Tự học / tra cứu

Ransomware: mã độc tống tiền

Hạn chế khả năng truy cập dữ liệu/hệ thống để đòi tiền. Mã hóa là cơ chế phổ biến; tống tiền bằng dữ liệu đánh cắp có thể đi kèm.

Wiper: mã độc phá hủy dữ liệu

Ghi đè hoặc phá hỏng dữ liệu nhằm gây mất khả dụng. Không giả định có thể khôi phục chỉ vì xuất hiện thông báo đòi tiền.

Nguồn: CISA, #StopRansomware Guide; MITRE T1485

Infostealer, spyware và keylogger

Tự học / tra cứu

Phân biệt phạm vi

Infostealer tập trung lấy dữ liệu như thông tin xác thực, cookie hoặc ví. Spyware theo dõi hoạt động người dùng. Keylogger ghi thao tác bàn phím, có thể là một thành phần của spyware.

Bằng chứng cần tách

Đọc dữ liệu không đồng nghĩa đã gửi ra ngoài; cần kiểm tra cả thu thập và truyền dữ liệu.

Nguồn: Sikorski & Honig, Practical Malware Analysis

Bot, botnet và RAT

Tự học / tra cứu

Bot và botnet

Bot là thành phần nhận điều khiển để thực hiện nhiệm vụ. Botnet là mạng các thiết bị bị điều khiển, có thể dùng kiến trúc tập trung hoặc ngang hàng.

Remote Access Trojan (RAT)

Trojan cho phép điều khiển trái phép từ xa. Phần mềm quản trị được cho phép không tự động là RAT độc hại; cần xem quyền và ngữ cảnh.

Nguồn: Sikorski & Honig, Practical Malware Analysis

Dropper, downloader, loader và payload

Tự học / tra cứu

Thuật ngữ	Vai trò
Dropper	Đặt/giải phóng thành phần được mang theo.
Downloader	Tải thành phần tiếp theo từ nguồn khác.
Loader	Nạp/kích hoạt mã tiếp theo; có thể kèm chức năng tải.
Payload	Thành phần thực hiện chức năng được xét trong chuỗi.

Điểm phân biệt: Một chương trình có thể kiêm nhiều vai trò. Stage là một chặng triển khai, không đồng nghĩa C2.

Nguồn: Practical Malware Analysis; MITRE S0367: Emotet

Rootkit và bootkit

Tự học / tra cứu

Rootkit

Tập hợp cơ chế/phần mềm che giấu hiện diện hoặc hoạt động và hỗ trợ duy trì truy cập đặc quyền; có thể can thiệp cách hệ thống trả về thông tin.

Bootkit

Can thiệp chuỗi khởi động để mã chạy sớm. Rootkit không bắt buộc ở kernel; bootkit không phải mọi dạng persistence.

Nguồn: Matrosov, Rodionov & Bratus (2019), Rootkits and Bootkits

Macro malware và logic bomb

Tự học / tra cứu

Macro malware

Dùng ngôn ngữ macro của ứng dụng để thực thi chức năng độc hại. Chỉ gọi là macro virus khi có cơ chế tự nhân bản phù hợp.

Logic bomb

Mã kích hoạt hành vi gây hại khi điều kiện định trước thỏa mãn, như thời điểm hoặc trạng thái. Đây là cách kích hoạt, không phải đường lây.

Nguồn: NIST SP 800-83 Rev. 1; Practical Malware Analysis

Adware và cryptojacking

Tự học / tra cứu

Adware

Phần mềm hiển thị quảng cáo; chỉ nhãn adware chưa đủ xác định độc hại. Cần xét đồng thuận, thu thập dữ liệu và hành vi xâm phạm.

Cryptojacking

Chiếm tài nguyên tính toán để đào tiền mã hóa trái phép. CPU cao chỉ là dấu hiệu; tác vụ tính toán hợp lệ có thể tương tự.

Nguồn: NIST SP 800-83 Rev. 1; MITRE T1496.001: Compute Hijacking

Fileless không có nghĩa là không có dấu vết

Trọng tâm của kỹ thuật

Chuỗi thực thi có thể dựa nhiều vào bộ nhớ và công cụ sẵn có hợp lệ trên máy nạn nhân, giảm phụ thuộc vào tệp thực thi truyền thống.

Vẫn phải tìm bằng chứng

Có thể còn script, Registry, log, bộ nhớ và dấu vết mạng. Injection cũng không đồng nghĩa với fileless.

Nguồn: Liu và cộng sự (2024), Computers & Security 137, 103653

Một mẫu có thể mang nhiều nhãn

Tình huống

Ứng dụng giả công cụ học tập nạp thành phần đánh cắp dữ liệu, sau đó nhận lệnh từ xa.

Cách diễn đạt

Có tính chất Trojan ở cách ngụy trang; có vai trò loader và chức năng đánh cắp dữ liệu. Cần thêm bằng chứng để xác định botnet.

Nguyên tắc

Chọn nhãn theo câu hỏi đang trả lời; không ép mọi mẫu vào một loại duy nhất.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Kiểm tra nhanh: loại hay kỹ thuật?

Cá nhân · 1 phút

Phân nhóm ba mô tả: (1) tự lan giữa máy; (2) chạy mã trong tiến trình khác; (3) thu thập cookie trái phép.

Sản phẩm

Ghi góc nhìn phân loại và một điều chưa thể suy ra.

Đối chiếu ba góc nhìn

Gợi ý đáp án

(1) Cơ chế lan, gợi ý worm nếu chứng minh tự nhân bản. (2) Kỹ thuật injection. (3) Chức năng đánh cắp dữ liệu.

Giới hạn

Chưa thể suy ra tên họ mã độc, tác nhân hoặc toàn bộ chuỗi tấn công từ một mô tả.

3

Vòng đời và chuỗi hành vi

Câu hỏi trọng tâm

Từ các dấu vết rời rạc, làm sao giải thích mã đã hoạt động?

Một chuỗi minh họa để đặt câu hỏi



Điểm cần nhớ

Đây là sơ đồ học tập giản lược. Có thể bỏ qua, lặp hoặc đổi thứ tự bước; không phải mọi mẫu đều có C2.

Nguồn: MITRE ATT&CK: Get Started

Đường tiếp cận mục tiêu không phải loại mã độc

- Tập đính kèm, liên kết, ứng dụng giả hoặc thiết bị lưu trữ.
- Khai thác phần mềm dễ tổn thương hoặc chuỗi cung ứng.
- Lừa người dùng thực hiện thao tác không phù hợp.
- Cùng một đường tiếp cận có thể mang nhiều loại payload.

Nguồn: MITRE ATT&CK: Get Started

Nguyên nhân nhiễm: thao tác bị dẫn dụ

Đường vào

Email đính kèm, phần mềm giả hoặc trang “xác minh/sửa lỗi” có thể dẫn người dùng đến mã không tin cậy.

Điều kiện để gây hại

Tệp/liên kết đến máy chưa đồng nghĩa mã đã chạy. Cần có thao tác hoặc cơ chế kích hoạt vượt qua ranh giới tin cậy.

Nguồn: CISA AA20-280A (2020); Microsoft (2025), ClickFix

Nguyên nhân nhiễm: lỗ hổng và cấu hình

Điều kiện	Hệ quả cần kiểm chứng
Dịch vụ dễ tổn thương	Có đường khai thác từ máy khác; không nhất thiết cần nhấp chuột.
Thông tin đăng nhập bị lộ	Có thể bị dùng để truy cập và triển khai mã.
Quyền rộng, mạng phẳng	Có thể tăng phạm vi tác động/lan truyền sau xâm nhập.

Phân biệt

Nguyên nhân xâm nhập ban đầu khác điều kiện làm thiệt hại mở rộng.

Nguồn: MITRE S0366; MITRE T1078: Valid Accounts

Nguyên nhân nhiễm: chuỗi cung ứng

Tự học / tra cứu



Ranh giới tin cậy

Phần mềm phụ thuộc hoặc kênh cập nhật có thể mang mã bị cài cắm. Chữ ký hợp lệ hỗ trợ xác minh nguồn ký và tính toàn vẹn, không chứng minh mọi hành vi đều lành.

Nguồn: MITRE T1195.002; MITRE S0559

Tình huống xuyên suốt của buổi học



Điểm cần nhớ

Dữ liệu mô phỏng phục vụ học tập. Dự đoán: còn cần thông tin nào trước khi kết luận có mã độc?

Nối mỗi hành vi với một nguồn

Hành vi	Nguồn có thể kiểm tra	Giới hạn
Mở/chạy tệp	Tệp, hash, log tiến trình	Tồn tại tệp chưa chứng minh đã chạy
Tạo tác vụ	Cấu hình và log kích hoạt	Tạo thành công chưa chắc thực thi
Kết nối ngoài	Log mạng, DNS, ngửi cảnh	Kết nối chưa chắc là C2

Nguồn: MITRE ATT&CK: Get Started

MITRE ATT&CK: nguồn gốc và mục đích

2013: xuất phát từ nghiên cứu thực nghiệm

MITRE xây dựng ATT&CK trong môi trường nghiên cứu FMX để hệ thống hóa hành vi đối thủ và đánh giá khả năng phát hiện trên mạng Windows.

2015: công bố ra cộng đồng

ATT&CK trở thành cơ sở tri thức công khai, tiếp tục được cập nhật từ hành vi tấn công thực tế và đóng góp của cộng đồng.

Mục đích cốt lõi

Tạo ngôn ngữ chung về hành vi đối thủ, kết nối phân tích mã độc, nghiên cứu, mô phỏng tấn công và phòng thủ.

Nguồn: MITRE FAQ; MITRE: Threat-Informed Defense

ATT&CK giúp đặt tên hành vi: TTP

Tactics, Techniques and Procedures

- **Tactic:** mục đích chiến thuật.
- **Technique:** cách đạt mục đích đó.
- **Procedure:** cách triển khai cụ thể được quan sát trong thực tế.

Sub-technique: mức mô tả cụ thể hơn

Scheduled Task là sub-technique của *Scheduled Task/Job*. Một task cụ thể được tạo để chạy lại mã là ví dụ về procedure.

Nguyên tắc sử dụng

Nối hành vi với bằng chứng trước, tra kỹ thuật sau. Nhãn ATT&CK không thay thế kết luận điều tra.

Vì sao TTP có giá trị trong an ninh mạng?

Kết nối các nhóm chuyên môn

Người phân tích mã độc, chuyên viên tình báo, red team và blue team có thể trao đổi về cùng một hành vi dù sử dụng công cụ khác nhau.

So sánh theo cách hoạt động

Hash nhận diện tệp cụ thể. TTP giúp đối chiếu hành vi giữa các mẫu, công cụ và chiến dịch; hỗ trợ xây dựng giả thuyết.

Không suy diễn từ sự tương đồng

Trùng TTP không chứng minh cùng họ mã độc hoặc tác nhân. ATT&CK không quy định một chuỗi bước mà mọi cuộc tấn công phải thực hiện.

Nguồn: MITRE: Get Started; MITRE: ATT&CK Design and Philosophy

Ánh xạ một chuỗi theo ATT&CK

Hành vi mô phỏng	Tactic	Technique / sub-technique
Email mang tệp độc hại	Initial Access	T1566.001: Spearphishing Attachment
Người dùng mở tệp độc hại	Execution	T1204.002: Malicious File
Tạo task để chạy lại mã	Persistence	T1053.005: Scheduled Task
Mã hóa dữ liệu gây hại	Impact	T1486: Data Encrypted for Impact

Quy tắc ánh xạ

Gán hành vi có bằng chứng; không suy ra bước chưa quan sát. Mã kỹ thuật không phải tên loại mã độc. Thứ tự trên chỉ minh họa một chuỗi.

Nguồn: T1566.001; T1204.002; T1053.005; T1486

Ứng dụng: nghiên cứu mã độc và offense

Malware Analyst / Security Researcher

So sánh cơ chế giữa các mẫu, gán nhãn dữ liệu hành vi và đánh giá phương pháp phân tích. Sản phẩm: báo cáo, bộ dữ liệu hoặc thực nghiệm tái lập.

Red Team / Adversary Emulation

Dùng TTP để thiết kế kịch bản mô phỏng đối thủ trong phạm vi được ủy quyền. Sản phẩm: kế hoạch kiểm thử và bằng chứng thực hiện.

Yêu cầu đối với kết quả nghiên cứu

Ghi phiên bản ATT&CK, căn cứ ánh xạ, điều kiện thử nghiệm và giới hạn kết luận để người khác có thể kiểm tra lại.

Nguồn: MITRE: Adversary Emulation; Detections and Analytics; Version History

Ứng dụng defense: vận hành và phát hiện

SOC Analyst / Threat Hunter

Dùng hành vi để định hướng tìm kiếm và nối các dấu vết liên quan. Sản phẩm: hồ sơ điều tra hoặc giả thuyết sẵn tìm kèm bằng chứng và khoảng trống dữ liệu.

Detection Engineer

Chuyển kỹ thuật ưu tiên thành yêu cầu dữ liệu và logic phát hiện; kiểm tra trên hành vi độc hại lẫn hoạt động hợp lệ. Sản phẩm: luật phát hiện đã kiểm chứng.

Có nhãn chưa đồng nghĩa có hiệu quả

Cảnh báo mang nhãn ATT&CK chưa chứng minh phát hiện đúng hoặc bao phủ mọi biến thể. Cần kiểm tra ngữ cảnh, sai dương và bỏ sót.

Nguồn: MITRE: Detections and Analytics; How Should I Not Use ATT&CK?

Ứng dụng defense: tình báo và cải tiến

Threat Intelligence / Incident Response

CTI đối chiếu TTP giữa các chiến dịch. Đội ứng phó dùng hành vi để định hướng điều tra. Sản phẩm: báo cáo mối đe dọa và hồ sơ sự cố có căn cứ.

Security Architect / Purple Team

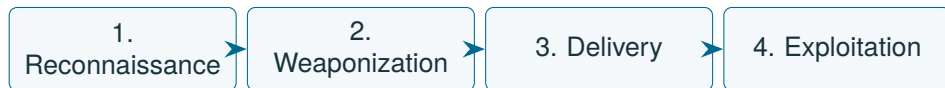
Ưu tiên kỹ thuật theo tài sản và mối đe dọa; phối hợp mô phỏng, quan sát và thử lại. Sản phẩm: đánh giá điểm thiếu và kế hoạch cải tiến.

Cầu nối sang Cyber Kill Chain

ATT&CK mô tả hành vi cụ thể. Cyber Kill Chain giúp tổ chức các giai đoạn xâm nhập. Hai khung hỗ trợ những câu hỏi ở cấp độ khác nhau.

Nguồn: MITRE: Threat Intelligence; Assessment and Engineering; Lockheed Martin: Cyber Kill Chain

Cyber Kill Chain: từ chuẩn bị đến kích hoạt



Diễn giải

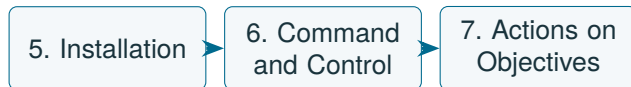
Trình sát mục tiêu → chuẩn bị phương tiện tấn công → chuyển đến mục tiêu → khai thác điểm yếu để kích hoạt mã.

Góc nhìn phân tích

Hai bước đầu thường nằm ngoài máy nạn nhân; thiếu log không chứng minh chúng không xảy ra.

Nguồn: Lockheed Martin, Cyber Kill Chain

Cyber Kill Chain: từ cài đặt đến mục tiêu



Diễn giải

Thiết lập mã trên hệ thống → liên lạc điều khiển → thực hiện mục tiêu như lấy dữ liệu hoặc phá hoại.

Điểm can thiệp

Tìm bằng chứng cài đặt, đích liên lạc và tác động. Dữ kiện từng ca có thể chỉ bao phủ một phần mô hình.

Nguồn: Lockheed Martin, Cyber Kill Chain

Dùng hai khung ở đúng cấp độ

Cyber Kill Chain

Mô hình các giai đoạn xâm nhập.
Giúp đặt câu hỏi về tiến trình chiến dịch.
Không ép mọi ca vào đủ bảy bước.

MITRE ATT&CK

Cơ sở tri thức về hành vi quan sát được.
Giúp gọi tên và kiểm chứng kỹ thuật cụ thể.
Không đọc ma trận như thứ tự bắt buộc.

Cách kết hợp

Dựng timeline từ chứng cứ, dùng Kill Chain để tổ chức câu hỏi, rồi gán ATT&CK. Đây là cách vận dụng của bài học; không có ánh xạ một-một mặc định.

Nguồn: Lockheed Martin; MITRE: Get Started

Ca thực tế: Emotet qua email (2020)



Bằng chứng công bố

CISA mô tả tệp đính kèm độc hại và sự phụ thuộc vào thao tác người dùng: T1566.001, T1204.002.

Phân tích

Delivery khác Execution: nhận thư chưa chứng minh chạy mã. Vai trò downloader không có nghĩa Emotet tự lây theo cơ chế virus. Đây là chuỗi lịch sử, không đại diện mọi biến thể.

Nguồn: CISA AA20-280A; MITRE S0367

Ca thực tế: WannaCry lan qua SMB (2017)



Cơ chế được ghi nhận

Khai thác SMBv1 để lan: T1210. Mã hóa dữ liệu gây tác động: T1486. Vì vậy vừa có chức năng ransomware vừa có đặc tính worm.

Giới hạn

Sơ đồ mô tả lan truyền từ máy đã nhiễm, không khẳng định đường vào đầu tiên của mọi tổ chức.

Nguồn: MITRE S0366: WannaCry

Ca thực tế: SUNBURST (2020)



Hai cấp phân tích

Chiến dịch chuỗi cung ứng: T1195.002. Mẫu SUNBURST: DLL bị trojan hóa, dùng HTTP/DNS cho C2 (T1071.001/.004).

Bài học

Việc cập nhật hợp lệ về tiến trình không loại trừ thành phần bị cài cắm. Phân biệt đường phân phối của chiến dịch với hành vi của mẫu.

Nguồn: MITRE S0559; MITRE C0024

Ca thực tế: ClickFix và Lumma (2025)



Kỹ thuật và mã độc

Microsoft ghi nhận ClickFix phân phối Lumma. ClickFix là kỹ thuật dẫn dụ, không phải họ mã độc; T1204.004 mô tả sao chép/dán độc hại.

Phân tích

Mục tiêu là khiến người dùng tự vượt ranh giới thực thi. Cần cây tiến trình và ngữ cảnh trang; một lệnh PowerShell riêng lẻ chưa đủ quy kết.

Nguồn: Microsoft, 21/08/2025; MITRE T1204.004

Chuỗi hợp lệ cũng có hình dạng tương tự

Phản ví dụ

Hệ thống quản trị mở script cập nhật, tạo lịch kiểm tra và kết nối tới máy chủ của đơn vị.

Cần đối chiếu

Nguồn phát hành, quyền cho phép, nội dung script, đích mạng và lịch triển khai.

Cầu nối

Muốn phân biệt hai chuỗi, phải biết đâu là quan sát và đâu là suy luận.

4

Phân tích dựa trên bằng chứng

Câu hỏi trọng tâm

Làm sao đưa ra kết luận có thể kiểm tra lại?

Ba cách nhìn cùng một mẫu

Cách phân tích	Câu hỏi	Giới hạn
Tĩnh	Tệp chứa gì, cấu trúc ra sao?	Mã có thể đóng gói hoặc chưa được thực thi
Động	Điều gì xảy ra khi chạy?	Chỉ thấy hành vi trong điều kiện quan sát
Kết hợp	Tệp, bộ nhớ, log có nhất quán?	Vẫn cần ngữ cảnh và đối chứng

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Công cụ hỗ trợ đọc bằng chứng

- Ghidra: đọc mã và cấu trúc chương trình.
- Debugger: theo dõi thực thi.
- Wireshark, log hệ thống: quan sát kết nối và tiến trình.
- Chọn công cụ theo câu hỏi, không theo số lượng.



Nguồn: NSA: Ghidra; Wireshark User's Guide

Quan sát, suy luận và điều chưa biết

Loại phát biểu	Ví dụ
Quan sát	Log ghi script tạo một scheduled task lúc 09:02.
Suy luận	Task có thể phục vụ duy trì thực thi.
Chưa biết	Task có được kích hoạt? Ai cho phép? Payload thực hiện gì?

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Nguyên tắc kết luận khi phân tích mã độc

1. Dựa trên bằng chứng

Phân biệt điều đã quan sát với điều đang suy luận. Mỗi kết luận cần có dữ kiện hỗ trợ; một dấu hiệu đáng nghi chưa đủ chứng minh mã độc.

2. Nêu rõ phạm vi và giới hạn

Kết luận trong điều kiện đã kiểm tra. Chưa quan sát thấy hành vi không có nghĩa hành vi không tồn tại; nêu rõ thông tin còn thiếu.

3. Kiểm chứng và cập nhật

Xem xét cách giải thích khác, bổ sung bằng chứng và thử đối chứng. Điều chỉnh kết luận khi có dữ kiện mới.

Vòng kiểm chứng giả thuyết



Điểm cần nhớ

Lưu phiên bản công cụ, cấu hình, hash và thời gian. Người khác phải kiểm tra lại được lập luận.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

Không quan sát thấy không có nghĩa là không tồn tại

Ví dụ

Mẫu không tạo kết nối trong 30 giây quan sát. Có thể thiếu điều kiện kích hoạt hoặc môi trường không phù hợp.

Diễn đạt đúng phạm vi

Trong cấu hình và khoảng thời gian này, chưa quan sát kết nối; cần thử thêm điều kiện đã xác định.

Nguồn: Sikorski & Honig (2012), Practical Malware Analysis

5

Luyện tập và đánh giá cá nhân

Câu hỏi trọng tâm

Có thể tự phân loại và bảo vệ kết luận trên dữ liệu mới không?

Hoạt động theo cặp: bốn thẻ A

Think–Pair–Share · 8 phút

Cá nhân 2 phút; trao đổi 4 phút; thống nhất 2 phút. Với mỗi thẻ: chọn góc nhìn phân loại, nêu bằng chứng và một điều chưa biết.

Thẻ dữ kiện

Các thẻ là trích lược hồ sơ giả định, không phải cùng một máy.

A1: mã gắn vào tệp và tiếp tục lây khi chạy.

A2: mã tự nhân bản giữa các máy.

A3: công cụ giả âm thầm lấy cookie.

A4: PowerShell chạy script cập nhật.

Phiếu trả lời và phản biện

Sản phẩm của cặp

Bốn dòng: mã thẻ | nhân có căn cứ | dấu vết hỗ trợ | cần kiểm tra thêm.

Chia sẻ · 5 phút

Hai cặp giải thích A3 và A4. Cặp nghe nêu một giả thuyết thay thế hoặc một dấu vết có thể bác bỏ kết luận.

Đối chiếu thẻ A

Thẻ	Kết luận có căn cứ	Điều chưa biết
A1	Cơ chế virus	Vật chủ, cách chèn và tác động
A2	Gợi ý worm nếu đúng tự nhân bản	Đường lan và điều kiện kích hoạt
A3	Trojan + chức năng đánh cắp	Dữ liệu đã rời máy hay chưa
A4	Chưa đủ kết luận mã độc	Script, quyền, nguồn và đích mạng

Phân tích thẻ A: điều kiện làm đôi kết luận

Tự học / tra cứu

A1 và A2

A1 cần cơ chế sao chép vào vật chủ, không chỉ sửa một tệp. A2 cần tự nhân bản; việc quản trị viên chép phần mềm sang máy khác chưa phải worm.

A3 và A4

A3: nguy trang và lấy dữ liệu là hai góc nhìn. A4: kiểm tra nguồn script và quyền; PowerShell là công cụ, không phải kết luận về ý đồ.

Sửa một kết luận quá mạnh

Phát biểu cần sửa

“A4 chắc chắn là mã độc fileless vì có PowerShell và không thấy tệp EXE mới.”

Cặp đôi · 4 phút

Viết lại kết luận tối đa hai câu; nêu hai bằng chứng cần bổ sung.

Gợi ý sửa và chuyển sang bài cá nhân

Gợi ý

Đã thấy PowerShell thực thi nhưng chưa đủ chứng minh chức năng độc hại. Cần nội dung script và ngữ cảnh cho phép; không thấy EXE mới không loại trừ dấu vết trên đĩa.

Trước khi làm bài

Phân loại theo cơ chế, dẫn đúng dữ kiện, nêu giới hạn. Bài tiếp theo dùng bộ B mới.

Bài cá nhân 1: tình huống B1–B3

5 phút thảo luận

Năm hồ sơ độc lập, chỉ dùng dữ kiện đề bài. Mỗi tình huống: phân loại/nhận định, một dẫn chứng và một giới hạn. Không dùng AI; nộp trước khi GV công bố gợi ý.

Dữ kiện mô phỏng

B1: mã chèn vào tài liệu; tài liệu mở thì mã sao chép sang tài liệu khác.

B2: chương trình tự sao chép tới máy khác, không gắn tệp chủ.

B3: tiện ích giả lấy dữ liệu trình duyệt mà người dùng không cho phép.

Bài cá nhân 1: tình huống B4–B5

Tiếp tục cùng bài 15 phút

B4: chương trình làm dữ liệu không truy cập được bằng mã hóa và hiển thị yêu cầu trả tiền.

B5: script quản trị tạo task; log ghi kết nối tới tên miền chưa xác minh. Chưa có nội dung script.

Cách chấm

Mỗi tình huống 2 điểm: đúng 1; dẫn chứng 0,6; giới hạn 0,4. Tổng 10 điểm, quy đổi vào 3% môn.

Gợi ý phản hồi sau khi đã nộp

B1–B4

B1: virus theo cơ chế lây tài liệu. B2: worm. B3: nguy trang Trojan và chức năng đánh cắp. B4: ransomware; chưa biết khả năng khôi phục.

B5

Chưa đủ kết luận độc hại hoặc C2. Cần nội dung script, ngữ cảnh quyền và xác minh đích kết nối.

Tiêu chí

Chấp nhận nhãn tương đương nếu lập luận đúng; không suy ra họ mã độc hoặc tác nhân.

Phân tích bộ B: bảo vệ kết luận đến đâu?

Tự học / tra cứu

B1–B3: dẫn đúng dữ kiện

B1: “sao chép sang tài liệu khác” hỗ trợ nhân bản. B2: “không gắn tệp chủ” phân biệt worm.
B3: “giả” và “không cho phép” hỗ trợ nguy trang/đánh cắp.

B4–B5: tránh suy quá xa

B4 chưa cho biết có lấy dữ liệu trước mã hóa. B5 chưa chứng minh C2; cần nội dung script, quyền và đích mạng. Không suy tên họ hoặc tác nhân.

6

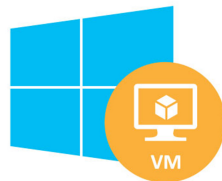
An toàn thực hành và bối cảnh AI

Câu hỏi trọng tâm

Phân tích như thế nào để bảo vệ dữ liệu và giữ chất lượng kết luận?

Môi trường lab trước khi chạy mẫu

- Chỉ dùng mẫu và dữ liệu GV cấp hoặc duyệt.
- Máy ảo, mạng cô lập; không bridge ra mạng thật.
- Snapshot; tắt chia sẻ thư mục và clipboard.
- Không dùng tài khoản hay dữ liệu cá nhân thật.



Nguồn: NIST SP 800-83 Rev. 1

Khi nghi ngờ mẫu thoát phạm vi



Điểm cần nhớ

Không tự thử trên máy thật. Phục hồi theo hướng dẫn sau khi bảo toàn thông tin cần thiết.

AI xuất hiện ở những vai trò khác nhau

Vai trò	Câu hỏi phải kiểm chứng
Hỗ trợ tạo mã/nội dung	Nguồn nào chứng minh AI được dùng?
Được gọi khi chương trình chạy	Có dấu vết gọi mô hình và sử dụng đầu ra không?
Hỗ trợ người phân tích	Kết luận nào đã được đối chiếu bằng chứng?

Nguồn: GTIG (2025), AI Threat Tracker

Không suy khả năng từ tên sản phẩm AI

Bằng chứng cần phân biệt

Hoạt động thực tế được quan sát khác với nguyên mẫu hoặc khả năng được quảng bá. GTIG phân biệt PROMPTSTEAL trong hoạt động với PROMPTFLUX ở giai đoạn thử nghiệm.

Đối với người học

AI có thể đề xuất giả thuyết; log, mã và nguồn sơ cấp mới giúp kiểm chứng một khẳng định.

Nguồn: GTIG (2025), AI Threat Tracker

Kiểm tra nhanh: có nên gửi mẫu cho AI?

Cá nhân · 1 phút

Bạn định tải memory dump chứa dữ liệu người dùng lên dịch vụ AI công cộng để hỏi nguyên nhân. Cần thay đổi điều gì?

Sản phẩm

Nêu một rủi ro dữ liệu và một cách học thay thế.

Đối chiếu lựa chọn có trách nhiệm

Cách làm

Không tải mẫu hoặc dữ liệu nhạy cảm lên dịch vụ công cộng. Dùng artefact đã làm sạch do GV cung cấp hoặc đầu ra AI tĩnh để kiểm chứng.

Giới hạn quyền

Chỉ dẫn nằm trong mẫu phải được coi là dữ liệu không đáng tin; không tự động làm theo hoặc cấp quyền thực thi.

7

Kết thúc buổi học

Câu hỏi trọng tâm

Điều gì cần giữ lại để bước sang cấu trúc tệp thực thi?

Sách học phần: Phân tích mã độc

Tự học / tra cứu

- Malware Analysis and Detection Engineering. A. Mohanta; A. Saldanha (2020). Apress. Tĩnh, động và xây dựng phát hiện.
- Learning Malware Analysis. Monnappa K A (2018). Packt. Quy trình phân tích Windows.
- Practical Malware Analysis. M. Sikorski; A. Honig (2012). No Starch Press. Nguyên lý và bài tập phân tích.

Cách đọc

Chọn chương theo chủ đề; ví dụ và giao diện cũ cần đối chiếu đặc tả hiện hành. Không cần đọc toàn bộ các sách để học.

Sách học phần: Hệ điều hành và dịch ngược

Tự học / tra cứu

- Windows Internals, Part 1, 7th ed.. P. Yosifovich và cộng sự (2017). Microsoft Press. Tiến trình, luồng và bộ nhớ.
- Windows Internals, Part 2, 7th ed.. A. Allievi và cộng sự (2021). Microsoft Press. I/O, bảo mật và thành phần hệ thống.
- Practical Reverse Engineering. B. Dang; A. Gazet; E. Bachaalany (2014). Wiley. x86/x64, ARM và Windows kernel.

Cách đọc

Chọn chương theo chủ đề; ví dụ và giao diện cũ cần đối chiếu đặc tả hiện hành. Không cần đọc toàn bộ các sách để học.

Sách học phần: Công cụ và phương pháp

Tự học / tra cứu

- Malware Analyst's Cookbook and DVD. M. H. Ligh và cộng sự (2010). Wiley. Tự động hóa và điều tra mã độc.
- The IDA Pro Book, 2nd ed.. C. Eagle (2011). No Starch Press. Đọc disassembly và dùng IDA.
- Reversing: Secrets of Reverse Engineering. E. Eilam (2005). Wiley. Nền tảng tư duy dịch ngược.

Cách đọc

Chọn chương theo chủ đề; ví dụ và giao diện cũ cần đối chiếu đặc tả hiện hành. Không cần đọc toàn bộ các sách để học.

Sách học phần: Hướng chuyên sâu

Tự học / tra cứu

- Rootkits and Bootkits. A. Matrosov; E. Rodionov; S. Bratus (2019). No Starch Press. Che giấu và chuỗi khởi động.
- Malware Data Science. J. Saxe; H. Sanders (2018). No Starch Press. Học máy, dữ liệu và đánh giá.
- Evasive Malware (đọc bổ sung). K. Cucci (2024). No Starch Press. Rối mã và chống phân tích.

Cách đọc

Chọn chương theo chủ đề; ví dụ và giao diện cũ cần đối chiếu đặc tả hiện hành. Không cần đọc toàn bộ các sách để học.

Nguồn ngoài: định nghĩa và khung phân tích

Tự học / tra cứu

- NIST (2013). SP 800-83 Rev. 1: Guide to Malware Incident Prevention and Handling.
- NIST (2020). SP 800-181 Rev. 1: NICE Framework.
- MITRE. ATT&CK: Get Started; các trang kỹ thuật được liên kết tại ca học.
- Lockheed Martin. Cyber Kill Chain; Hutchins, Cloppert & Amin (2011), mô hình phòng thủ dựa trên tình báo.
- Liu và cộng sự (2024). A survey on the evolution of fileless attacks and detection techniques. Computers & Security 137, 103653.

Nguồn ngoài: ca thực tế và bối cảnh AI

Tự học / tra cứu

- CISA (2020). Emotet Malware, AA20-280A. MITRE S0367.
- MITRE S0366: WannaCry. S0559: SUNBURST. C0024: SolarWinds Compromise.
- Microsoft (21/08/2025). Think before you Click(Fix): Analyzing the ClickFix social engineering technique.
- GTIG (2025). AI Threat Tracker: Advances in Threat Actor Usage of AI Tools.

Khi tự học

Liên kết nằm trong tiêu đề nguồn. Đọc mốc thời gian và phạm vi quan sát; không suy mọi biến thể có cùng hành vi. Rà soát nguồn: 08/09/2026.

Tóm tắt bài học

- Phân loại theo cơ chế nhân bản, kỹ thuật hoặc chức năng; các nhãn có thể đồng thời đúng.
- Kill Chain tổ chức giai đoạn; ATT&CK mô tả hành vi, không quy định chuỗi bắt buộc.
- Tách quan sát, suy luận và điều chưa biết; dùng đối chứng.
- Học phần đánh giá bằng chứng và năng lực cá nhân. Đề án được giao tuần 3.
- Sau 48 giờ: dựng lại vòng đời; chuẩn bị PE cho Buổi 2.

Exit Ticket 3–2–1: kiểm tra hiểu bài

Cá nhân · 5 phút

- ➊ **3 khái niệm:** Định nghĩa ngắn gọn **virus, worm và Trojan**. Với mỗi loại, nêu đặc điểm dùng để phân biệt với hai loại còn lại.
- ➋ **2 điểm khác biệt:** Phân biệt **phân phối với thực thi**, và **tự nhân bản với tải thêm thành phần**. Viết một câu cho mỗi cặp.
- ➌ **1 sơ đồ vòng đời:** Vẽ một chuỗi hoạt động mã độc đã học bằng mũi tên; ghi chức năng ngắn cho từng bước. Chú thích một bước có thể không xuất hiện trong mọi mã độc.

Nộp và tự kiểm tra

Nộp 3 định nghĩa, 2 câu phân biệt và 1 sơ đồ. Tiêu chí: đúng đặc điểm; không nhầm các bước; hiểu vòng đời có thể thay đổi. Không yêu cầu mã ATT&CK.